

Cybersecurity Daily Newsletter

Vol. 002 | 2026-06-28 07:00 WIB

Top 5 Highlights

- Clean GitHub repo tricks AI coding agents into running malware
- [+24h Old] FBI: Russian hackers now target Signal backup recovery keys
- [+24h Old] CISA sets urgent deadline to fix Cisco flaw exploited in attacks
- [+24h Old] Polymarket customers lose \$3 million in supply-chain attack
- [+24h Old] Cybersecurity firms targeted by fraudulent OpenAI organization invites

Threat Intelligence (10)

01. Clean GitHub repo tricks AI coding agents into running malware

An agentic coding tool tasked with cloning and setting up a seemingly benign GitHub repository could execute a malicious payload that remains invisible to security scanners, AI agents, and human reviewers. [...]

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: <https://www.bleepingcomputer.com/news/security/clean-github-repo-tricks-ai-coding-agents-into-running-malware/>

02. [+24h Old] FBI: Russian hackers now target Signal backup recovery keys

The FBI and CISA are warning that a phishing campaign targeting Signal users tied to Russian intelligence services has evolved to steal Signal Backup Recovery Keys, allowing attackers to access victims' historical messages. [...]

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Tighten email authentication and filtering, run targeted user awareness, and monitor for lookalike domains and suspicious inbox rules.

Sources: <https://www.bleepingcomputer.com/news/security/fbi-russian-hackers-now-target-signal-backup-recovery-keys/>

03. [+48h Old] Order-tracking app Shop abused to push callback phishing attacks

Threat actors are increasingly abusing Shop, the order-tracking app from Shopify, by adding fake purchase receipts in users' order histories to trick them into providing sensitive data or installing remote access software. [...]

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Tighten email authentication and filtering, run targeted user awareness, and monitor for lookalike domains and suspicious inbox rules.

Sources: <https://www.bleepingcomputer.com/news/security/order-tracking-app-shop-abused-to-push-callback-phishing-attacks/>

04. [+48h Old] New macOS malware embeds fake errors to confuse AI analysis tools

A newly discovered macOS malware dubbed "Gaslight" is designed to confuse AI-assisted malware analysis tools by hiding prompt injection strings and fake debugging data within the executable. [...]

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: <https://www.bleepingcomputer.com/news/security/new-macos-malware-embeds-fake-errors-to-confuse-ai-analysis-tools/>

05. [+48h Old] Bluekit phishing kit adopts browser-in-the-middle for login theft

The Bluekit phishing-as-a-service platform continues to evolve with nearly 70 new hostnames identified over the past week and by adding browser-in-the-middle capabilities for improved data theft. [...]

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Tighten email authentication and filtering, run targeted user awareness, and monitor for lookalike domains and suspicious inbox rules.

Sources: <https://www.bleepingcomputer.com/news/security/bluekit-phishing-kit-adopts-browser-in-the-middle-for-login-theft/>

06. [+48h Old] ANY.RUN & Torq Integration: Scale Triage & Respond with Confidence

Lack of alert context makes it difficult for Security Operations Centers (SOC) to distinguish actual threats from false positives. ANY.RUN's integration with the Torq AI SOC Platform bridges this gap by delivering conclusive malware & phishing verdicts and actionable intelligence. The result for your team is faster incident resolution, reduced alert fatigue...

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Tighten email authentication and filtering, run targeted user awareness, and monitor for lookalike domains and suspicious inbox rules.

Sources: <https://any.run/cybersecurity-blog/torq-integration/>

07. [+48h Old] Malicious Edge extension abuses Native Messaging as bridge to malware

A malicious Microsoft Edge extension dubbed 'Edgecution' has been used in a ransomware attack to escape the browser sandbox and deploy a Python-based backdoor. [...]

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: <https://www.bleepingcomputer.com/news/security/malicious-edge-extension-abuses-native-messaging-as-bridge-to-malware/>

08. [+48h Old] New macOS ClickFix attack silently mounts DMGs to push infostealer

A new macOS ClickFix campaign is using Terminal commands to silently download, mount, and launch info-stealing malware from malicious disk image (DMG) files. [...]

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: <https://www.bleepingcomputer.com/news/security/new-macos-clickfix-attack-silently-mounts-dmgs-to-push-infostealer/>

09. [+48h Old] Webinar: Why email security teams are drowning in alerts

Phishing, BEC, and account takeover attacks continue to overwhelm security teams with alerts and investigations. This webinar explores how behavioral AI can help automate detection and response workflows, reducing alert fatigue and improving operational efficiency. [...]

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Tighten email authentication and filtering, run targeted user awareness, and monitor for lookalike domains and suspicious inbox rules.

Sources: <https://www.bleepingcomputer.com/news/security/webinar-why-email-security-teams-are-drowning-in-alerts/>

10. [+48h Old] WhatsApp phishing attack uses fake business docs to hack PCs

An ongoing malware campaign is targeting WhatsApp users in multiple countries with deceptive messages that push VBScript files, leading to remote system access. [...]

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Tighten email authentication and filtering, run targeted user awareness, and monitor for lookalike domains and suspicious inbox rules.

Sources: <https://www.bleepingcomputer.com/news/security/whatsapp-phishing-attack-uses-fake-business-docs-to-hack-pcs/>

Latest Vulnerabilities (10)

01. [+24h Old] CISA sets urgent deadline to fix Cisco flaw exploited in attacks

The U.S. Cybersecurity and Infrastructure Security Agency (CISA) is giving federal agencies until Sunday to patch a vulnerability in Cisco Unified Communications Manager Server that is being actively exploited. [...]

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: <https://www.bleepingcomputer.com/news/security/cisa-sets-urgent-deadline-to-fix-cisco-flaw-exploited-in-attacks/>

02. [+48h Old] Mandiant reveals how Cisco SD-WAN zero-day attacks gained root access

New details have been revealed on how hackers exploited a Cisco Catalyst SD-WAN vulnerability tracked as CVE-2026-20245 in zero-day attacks to create rogue root accounts on targeted devices. [...]

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: <https://www.bleepingcomputer.com/news/security/mandiant-reveals-how-cisco-sd-wan-zero-day-attacks-gained-root-access/>

03. [+48h Old] Restrict AWS Management Console access to expected networks with sign-in resource-based policies and RCPs

Amazon Web Services (AWS) recently announced support for resource-based policies and resource control policies (RCPs) for AWS Sign-In. By using resource-based policies and RCPs, you can restrict access to the AWS Management Console sign-in and aws login CLI sessions to requests from your expected networks, your on-premises data center networks, and your Ama...

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: <https://aws.amazon.com/blogs/security/restrict-aws-management-console-access-to-expected-networks-with-sign-in-resource-based-policies-and-rcps/>

04. [+48h Old] CISA warns of max severity Ubiquiti flaws exploited in attacks

The U.S. Cybersecurity and Infrastructure Security Agency (CISA) is warning of hackers actively exploiting flaws in Ubiquiti UniFi OS and Lantronix serial-to-ethernet servers. [...]

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: <https://www.bleepingcomputer.com/news/security/cisa-warns-of-max-severity-ubiquiti-flaws-exploited-in-attacks/>

05. [+48h Old] Cisco Unified CM flaw CVE-2026-20230 now exploited in attacks

A high-severity SSRF vulnerability, tracked as CVE-2026-20230, in Cisco Unified Communications Manager Server is now being exploited in attacks. [...]

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: <https://www.bleepingcomputer.com/news/security/cisco-unified-cm-sme-flaw-cve-2026-20230-now-exploited-in-attacks/>

06. [+48h Old] The Exploit Doesn't Exist. You Can Still Prove It Works Against You

Attackers can now weaponize newly disclosed vulnerabilities far faster than most organizations can patch them. Picus Security explains how security teams can validate exploitability before a public exploit even exists. [...]

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: <https://www.bleepingcomputer.com/news/security/the-exploit-doesnt-exist-you-can-still-prove-it-works-against-you/>

07. [+48h Old] LastPass confirms data breach in Klue supply chain attack

LastPass announced that hackers accessed customer data from its Salesforce environment after stealing the company's OAuth tokens in the Klue supply chain attack earlier this month. [...]

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: <https://www.bleepingcomputer.com/news/security/lastpass-confirms-data-breach-in-klue-supply-chain-attack/>

08. [+48h Old] FFmpeg fixes PixelSmash flaw in widely used video decoder

A newly disclosed FFmpeg flaw dubbed 'PixelSmash' could be exploited for remote code execution on Jellyfin servers under certain conditions, and can also trigger a denial-of-service condition in applications like Kodi, Emby, Nextcloud, PhotoPrism, and OBS Studio. [...]

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: <https://www.bleepingcomputer.com/news/security/ffmpeg-fixes-pixelsmash-flaw-in-widely-used-video-decoder/>

09. [+48h Old] VU#936962: Multiple file parsing vulnerabilities in FastStone Image Viewer 8.3.0.0

Overview Two vulnerabilities have been identified in FastStone Image Viewer 8.3 that may allow remote code execution or control-flow corruption when processing specially crafted image files. The affected components include the JPEG 2000 (JP2) parser and the PSD file parser. An attacker can exploit these vulnerabilities by causing the application to automati...

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: <https://kb.cert.org/vuls/id/936962>

10. [+48h Old] Microsoft fixes AutoGen Studio flaw that enabled code execution

A vulnerability chain dubbed AutoJack in Microsoft's AutoGen Studio interface for prototyping AI agents could let attackers manipulate an agent into executing arbitrary commands on its host system simply by visiting a malicious webpage. [...]

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: <https://www.bleepingcomputer.com/news/security/microsoft-fixes-autogen-studio-flaw-that-enabled-code-execution/>

Data Breach & Cybercrime (10)

01. [+24h Old] Polymarket customers lose \$3 million in supply-chain attack

Polymarket says it will fully reimburse customers who lost an estimated \$3 million after hackers injected a malicious script into the platform's frontend following a breach at a third-party vendor. [...]

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: <https://www.bleepingcomputer.com/news/security/polymarket-customers-lose-3-million-in-supply-chain-attack/>

02. [+24h Old] Cybersecurity firms targeted by fraudulent OpenAI organization invites

Threat actors are creating OpenAI tenants that impersonate legitimate companies and inviting employees to join them, in what appears to be a ploy to trick targets into submitting sensitive company information in chats and projects. [...]

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: <https://www.bleepingcomputer.com/news/security/cybersecurity-firms-targeted-by-fraudulent-openai-organization-invites/>

03. [+48h Old] Poland busts SIM-swapping gang tied to millions in crypto theft

Authorities in Poland have arrested four members of an organized cybercrime group accused of breaching telecommunications partners and hijacking email accounts to carry

out SIM-swapping attacks. [...]

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: <https://www.bleepingcomputer.com/news/security/poland-busts-sim-swapping-gang-tied-to-millions-in-crypto-theft/>

04. [+48h Old] The Four Elevations of Effective Fraud Prevention

Fraudsters don't attack just one transaction. They target accounts, platforms, and entire ecosystems. IPQS explains the four elevations of fraud prevention and why broader visibility improves fraud detection. [...]

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources:

<https://www.bleepingcomputer.com/news/security/the-four-elevations-of-effective-fraud-prevention/>

05. [+48h Old] Amadey, StealC malware operations disrupted in Operation Endgame action

Microsoft, Europol, and international partners have disrupted infrastructure used by the Amadey and StealC malware operations as part of Operation Endgame, which targets cybercriminal services and ransomware gangs. [...]

Why it matters: Ransomware operations combine disruption with extortion, making recovery speed and data-resilience core business risks.

Recommendation: Verify offline backups, test restores, harden remote access, and review segmentation to limit lateral movement.

Sources: <https://www.bleepingcomputer.com/news/security/amadey-stealc-malware-operations-disrupted-in-operation-endgame-action/>

06. [+48h Old] Stealthy Mystic backdoor linked to ransomware access broker KongTuke

A new backdoor dubbed Mystic has been observed in financially motivated attacks targeting organizations in the insurance, education, IT, and professional services sectors. [...]

Why it matters: Ransomware operations combine disruption with extortion, making recovery speed and data-resilience core business risks.

Recommendation: Verify offline backups, test restores, harden remote access, and review segmentation to limit lateral movement.

Sources: <https://www.bleepingcomputer.com/news/security/stealthy-mystic-backdoor-linked-to-ransomware-access-broker-kongtuke/>

07. [+48h Old] Tata Electronics confirms cyberattack as hackers leak data

Tata Electronics has confirmed in a statement to BleepingComputer that it was the target of a cyberattack that impacted parts of its IT infrastructure. [...]

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: <https://www.bleepingcomputer.com/news/security/tata-electronics-confirms-cyberattack-as-hackers-leak-data/>

08. [+48h Old] Healthtech firm Xolis suffers data breach impacting 1.4 million people

Healthcare technology company Xolis says that sensitive data belonging to nearly 1.4 million individuals was compromised in a phishing attack that gave attackers access to its network. [...]

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: <https://www.bleepingcomputer.com/news/security/healthtech-firm-xolis-suffers-data-breach-impacting-14-million-people/>

09. [+48h Old] Scattered Spider members plead guilty to hacking Transport for London

Two members of the 'Scattered Spider' cybercrime group pleaded guilty to hacking the Transport for London (TfL) systems in 2024. [...]

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: <https://www.bleepingcomputer.com/news/security/scattered-spider-members-plead-guilty-to-hacking-transport-for-london/>

10. [+48h Old] Prevent data exfiltration: AWS egress controls for cloud workloads

When securing an Amazon Web Services (AWS) environment, teams naturally prioritize inbound controls, firewalls, WAFs, and access policies, because that's where the most visible threats originate. Outbound traffic, on the other hand, tends to get less attention. It's often left open by default to avoid breaking application dependencies and because the risk f...

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: <https://aws.amazon.com/blogs/security/prevent-data-exfiltration-aws-egress-controls-for-cloud-workloads/>